
Business Continuity Management

Outline

- BCP / BCM
- Security Threats
- HA
- DC / DRC

Business Continuity Plan (BCP)

BCP is a plan of countermeasures developed by/for an enterprise to protect human lives and to enable prompt recovery/continuity of its business activities in the face of accidents/disasters (including unordinary incidents). BCP should be developed and implemented well in advance for an enterprise to ensure its effectiveness.

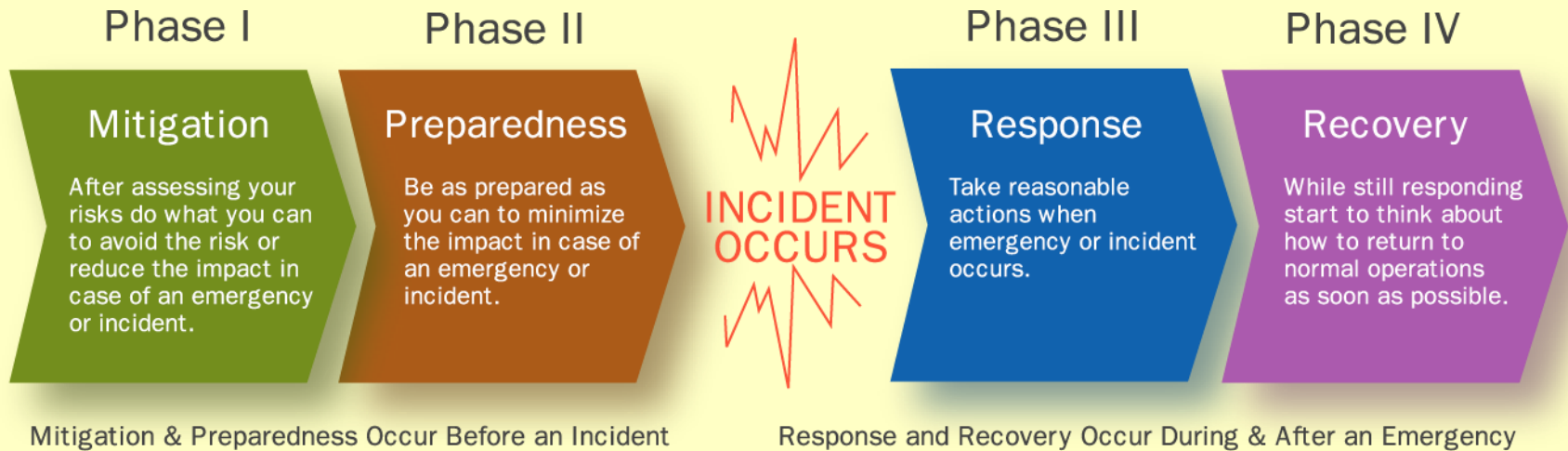
BCM

Activity that is concerned with developing an organisation's ability to continue providing critical services in the event of disaster.

- Identification and assessment of risks
- Implementation of prevention and mitigation activities
- Managing incidents
- Recovering and resuming business as usual activities.

*** BCM is a structure for maintenance/management of the BCP**

Phases of Continuity Planning



Examples

<https://www.kmutt.ac.th/wp-content/uploads/pdf/publications/BCP-KMUTT.pdf>

<https://www.mdes.go.th/law/download/1413>

https://www.mot.go.th/file_upload/2558/BCP2556.pdf

https://www.dga.or.th/wp-content/uploads/2015/10/file_f6e7c5291b074266bf88048cd154c302.pdf

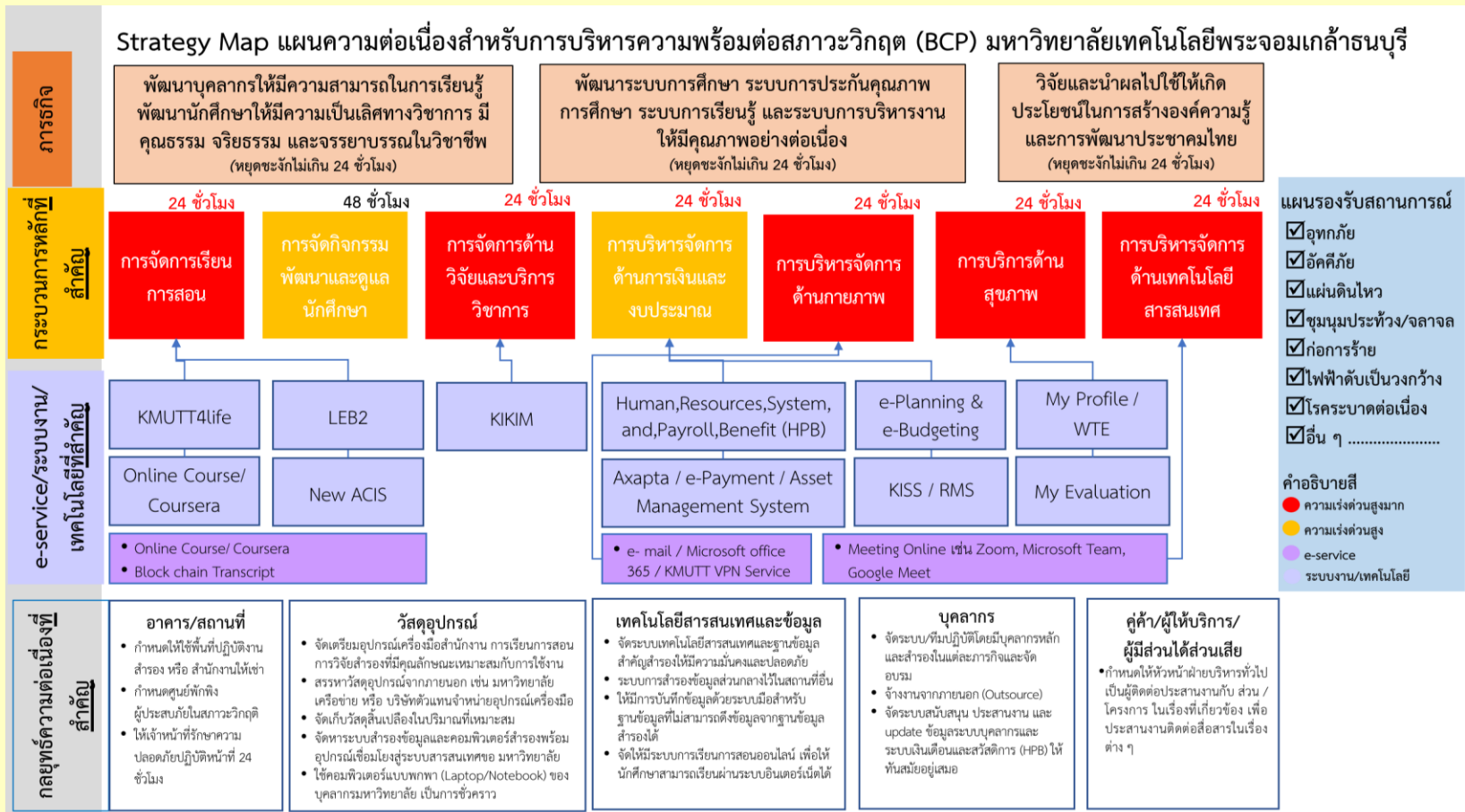
Risk Assessment

ความเสี่ยงและภัยคุกคาม	ผลกระทบ				
	ด้าน บุคลากรหลัก	ด้านอาคาร/ สถานที่ปฏิบัติ งานหลัก	ด้านวัสดุอุปกรณ์/ การจัดหาวัสดุ อุปกรณ์ที่สำคัญ	ด้านเทคโนโลยี สารสนเทศและ ข้อมูลที่สำคัญ	ด้านภาคีเครือข่าย /ผู้ให้บริการที่ สำคัญ
เหตุการณ์อัคคีภัย	✓	✓	✓	✓	
เหตุการณ์อุทกภัย	✓	✓	✓	✓	✓
เหตุการณ์वादภัย	✓	✓	✓	✓	
เหตุการณ์ภัยแล้ง	✓			✓	
เหตุการณ์ภัยทางอากาศ	✓				✓
เหตุการณ์แผ่นดินไหว	✓	✓	✓	✓	
เหตุการณ์ชุมนุมประท้วง/ จลาจล	✓				✓
เหตุการณ์โรคระบาด	✓	✓	✓	✓	✓
เหตุการณ์ภัยทาง เทคโนโลยีสารสนเทศ	✓		✓	✓	✓

Business Impact Analysis

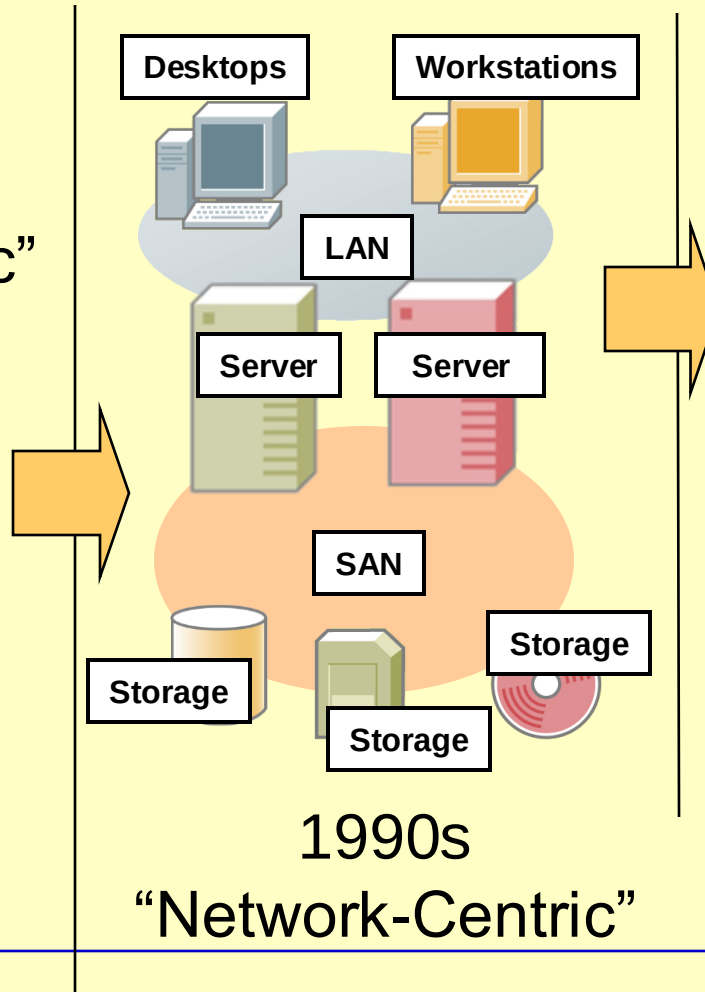
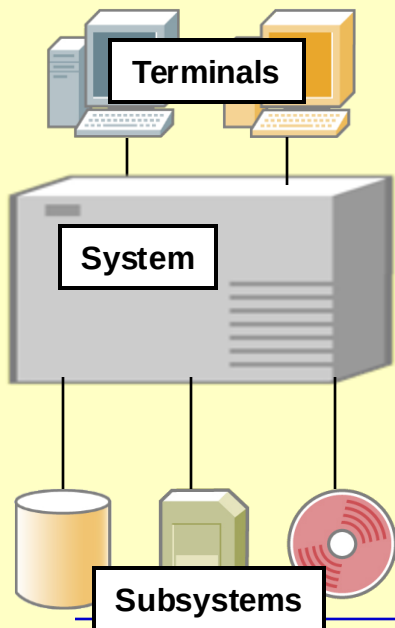
กระบวนการ	ระดับ ผลกระทบ/ ความแรงด่วน	ระยะเวลาเป้าหมายในการฟื้นคืนสภาพ				
		2 ชั่วโมง	24 ชั่วโมง	48 ชั่วโมง	1 สัปดาห์	2 สัปดาห์
การจัดการเรียนการสอน						
1) การเรียนการสอนในห้องเรียน	มาก			✓		
2) การเรียนการสอนในห้องปฏิบัติการ/โรงประลอง	มาก				✓	
3) การเรียนรู้ในรูปแบบอื่น ๆ เช่น WiL / Social Lab	มาก					✓
4) การเรียนการสอนออนไลน์ (Online) และ แบบผสม Hybrid	มาก	✓				

Strategy Map



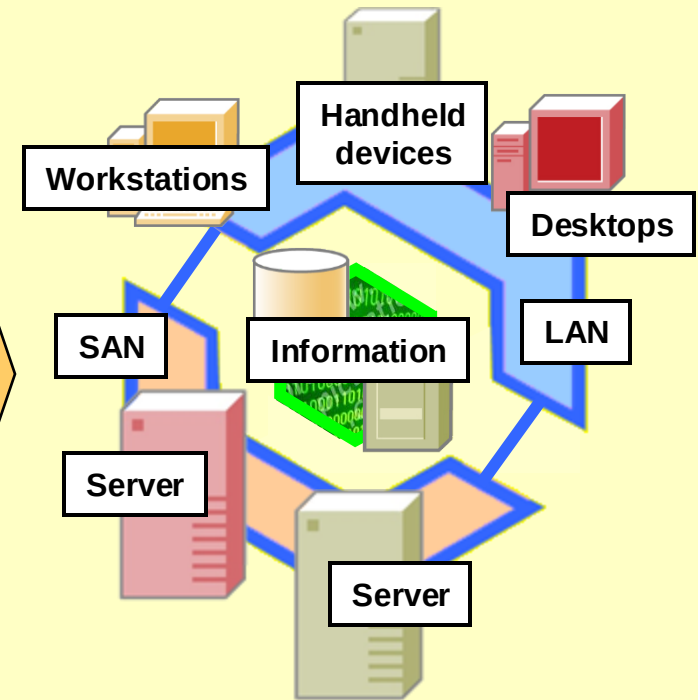
Information Era

1950s
“Server-Centric”



1990s

“Network-Centric”

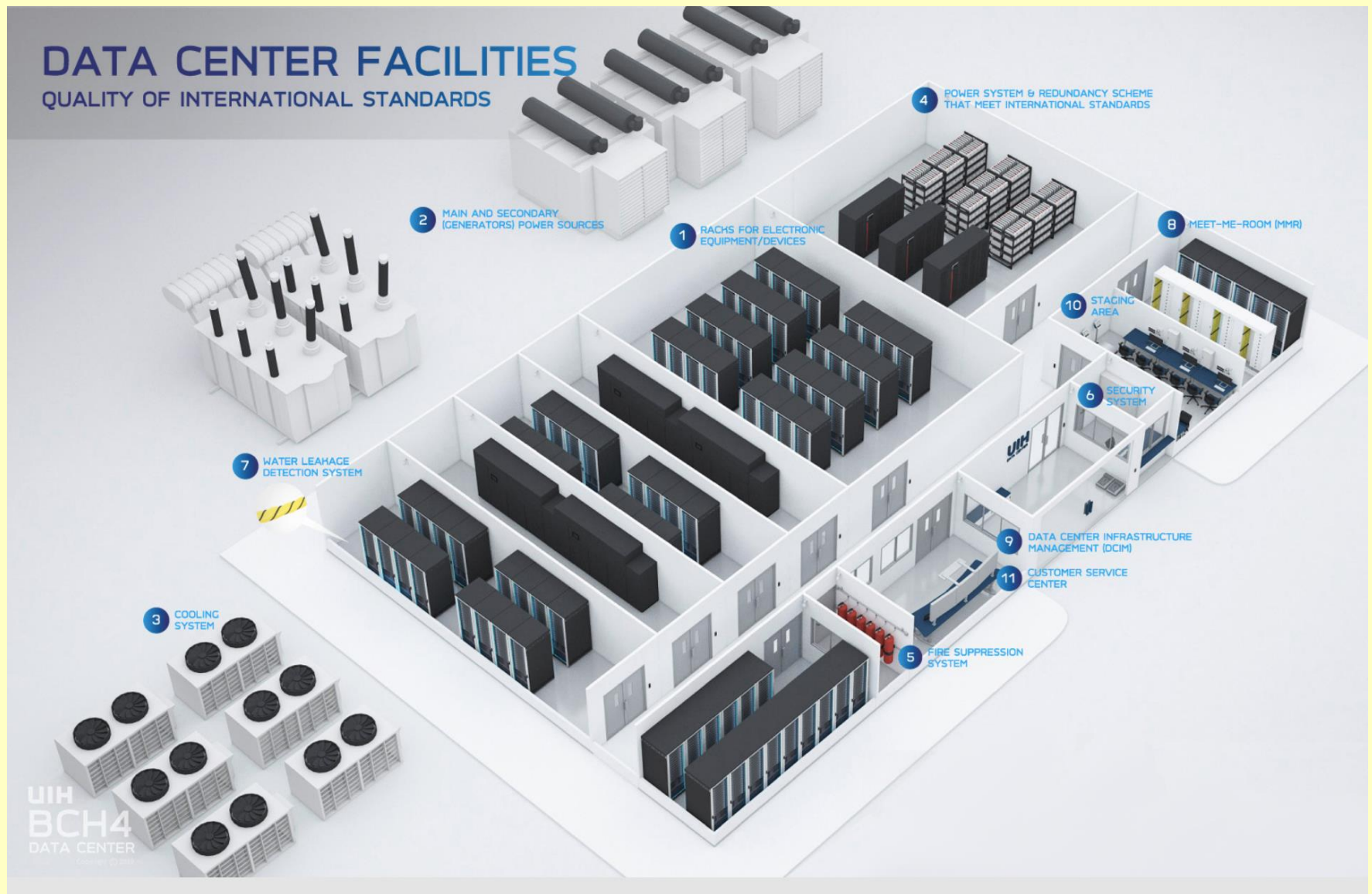


21st Century
“Information-Centric”

Data Center (DC)

DATA CENTER FACILITIES

QUALITY OF INTERNATIONAL STANDARDS



<https://datacenter.uih.co.th>





DATA CENTER



High Availability

High Availability (HA)

- **Reliability**
 - **Resiliency**
 - **Availability**
 - **Serviceability**
-

Reliability

Reliability represents the probability of a component or system not encountering any failures over a time span. Reliability is a measure of “not breaking down, once it is put in use.” The focus is on making the component or system unbreakable.

Resiliency

Resiliency is the property of a component that allows it to continue with full or partial functionality after one or more faults. Highly resilient components are able to detect and quickly compensate for faults.

An example is error-correction code (ECC) memory. If errors are detected, the bad area is taken out of service, and memory addresses are moved to another area that is properly functioning.

Availability

Availability measures the ability of a system or group of systems (cluster) to keep an application or service up and running.

Designing for availability assumes that systems will fail, and the systems are configured to mask and recover from component or server failures with minimum application outage.

Serviceability

Serviceability is the probability of a service being completed within a given time window.

Security Threats

Preventing Computer Viruses

- **Viruses spreads when infected files are accessed**
 - Macro viruses attach themselves to other programs (documents) and spread when the programs are executed (the files are opened)
- **Worms**
 - Special type of virus that spread itself without human intervention (sends copies of itself from computer to computer)
- **Anti-virus software packages check disks and files to ensure that they are virus-free**
- **Incoming e-mail messages are most common source of viruses**
 - Check attachments to e-mails, use filtering programs to 'clean' incoming e-mail

Preventing Denial of Service Attacks

- **DoS attacks**
 - Network disrupted by a flood of messages that prevents messages from normal users
 - Flooding web servers, email servers so server cannot respond
- **Distributed DoS (DDoS) come from many different computers**
 - DDoS agents on several machines are controlled by a DDoS handler, may issue instructions to computers to send simultaneous messages to a target computer
- **Difficult to prevent DoS and DDoS attacks**
 - Setup many servers around the world
 - Use Intrusion Detection Systems
 - Require ISPs to verify that all incoming messages have valid IP addresses

DOS and DDOS Approaches

- ***Traffic filtering:*** verify all incoming traffic source addresses for validity (requires a lot of processing)
- ***Traffic limiting:*** When a flood of packets are entering the network, limit incoming access regardless of source (some may be legitimate)
- ***Traffic anomaly detectors:*** Perform analysis of traffic to see what normal traffic looks like, block abnormal patterns

Intrusion Prevention

- **Types of intruders**
 - **Casual intruders**
 - **With Limited knowledge (“trying doorknobs”)**
 - **Script kiddies: Novice attackers using hacking tools**
 - **Security experts (hackers)**
 - **Motivation: the thrill of the hunt; show off**
 - **Crackers: hackers who cause damage**
 - **Professional hackers (espionage, fraud, etc)**
 - **Breaking into computers for specific purposes**
 - **Organization employees**
 - **With legitimate access to the network**
 - **Gain access to information not authorized to use**

Preventing Intrusion

- Requires a *proactive* approach that includes routinely testing the security systems
- Best rule for high security
 - Do not keep extremely sensitive data online
 - Store them in computers isolated from the network
- Security Policy
 - Critical to controlling risk due to access
 - Should define clearly
 - Important assets to be safeguarded and Controls needed
 - What employees should do
 - Plan for routinely training employees and testing security controls in place

Disaster

Causes of Disaster

DISASTER	CAUSES
Natural calamities	Storm, tornados, fire, earthquake, flood, high winds, heat
Man-made	Wars, military operations, vandalism, bomb threats, explosions, disgruntled employees, malicious destruction, data or computer theft, viruses, human error
Accidents	Plane crash, radiological accidents, explosions, office accidents, plumbing leaks
Technical breakdown	Hardware or software crash or failure, telecommunications outage, interruption of building operations and services, power outage, sprinkler failure

High Availability (HA) and Disaster Recovery (DR)

	HIGH AVAILABILITY (HA)	DISASTER RECOVERY (DR)
When to use it	To protect against host failures.	To protect against loss of an entire physical site or facility.
Configuration	Hosts are connected by heartbeat cables. They have shared storage and they use the same network and subnet.	Nothing is shared. The primary and secondary sites have independent servers, data storage, networks, and so on. Therefore, there are no distance limitations. Data from the primary site is replicated to the secondary site.
Location of servers	HA servers are usually in the same data center, sometimes even in the same cabinet (bad idea because the network or power failure in the cabinet would take all redundant servers), or just a few meters apart in different cabinets or on different floors. If they are farther than that, you could run into length (disk or heartbeat cable) limitations.	The primary and secondary sites are several kilometers apart. If they are far enough apart, the chances a disaster would impact both sites is decreased.

High Availability (HA) and Disaster Recovery (DR) (Cont.)

	HIGH AVAILABILITY (HA)	DISASTER RECOVERY (DR)
When to use it	To protect against host failures.	To protect against loss of an entire physical site or facility.
Process of recovery	The recovery process in a cluster is simple. If a server fails, applications failover to the other healthy members in the cluster automatically with no impact on clients or users. After a failed server is repaired, it can be easily brought back into the cluster as a standby or active member.	Recovery is complicated. After a disaster, it may be impossible to ever make the site the same as before. If the disks and data are destroyed, new disks will have to be set up and data restored from secondary site over the network or by using backup tapes.
Effect on clients	Clients and users do not feel the impact of a server failure. The application failover process from failed server is transparent to users.	If the primary site fails, all clients and users feel the effect. It may be necessary to relocate all users to the secondary site.

Designing a Disaster-Tolerant Architecture

- **Protecting data and nodes through geographic diversity**
 - **Off-line data replication**
 - **Online data replication**
 - **Alternative power sources for redundant servers and data**
 - **Disaster-tolerant networks**
-

Off-line data replication

- **Backup tapes and media must be stored offsite at another data center.**
 - **The remote data center must have enough servers and disks in cold-standby mode**
 - **Advantage**
 - Data on tape is always consistent.
 - The process is simple
 - Easy to document and execute.
 - **Disadvantage**
 - Data is not as up-to-date as the lost data in the primary site.
 - The process of recovery can take from a day to a week.
-

Online data replication

Online data replication is a process that copies data from one set of disks to another complete and independent set of disks located at a separate site and attached to a separate set of hosts.

- **Replication is not the same as mirroring. Mirroring treats the disk sets as a single logical volume**
 - **Replication, treats the disk sets as separate and independent of each other**
-

Online Replication Techniques

- **Online replication is a method of copying data from one site to another over a dedicated I/O or network link.**
 - **Synchronous replication requires writes to all data copies to be complete and replicated before the next write operation can begin.**
 - **Asynchronous replication does not require the server at the primary site to wait for data to be written to the remote.**
-

Common techniques of data replication

- **User-Level Replication**
 - **Software-Based Replication**
 - **Device Driver–Level Replication**
 - **Disk-Subsystem Hardware-Based Replication**
 - **Database Replication**
 - **Transaction-Based Replication**
 - **Process-Level State Replication**
-